SOURCE CODE SECURITY ASSESSMENT

BitTool Signer

1.0.0 版本安全审计报告

iOS 原生应用 · 离线 JavaScript 签名引擎 · 钱包安全

发布意见：暂缓发布用于真实资金的版本

已确认两项可导致用户误判实际资金支出的高风险审核缺陷。应修复、补充回归验证，并完成发行设备验收后再作安全放行决定。

0	2	1	1
CRITICAL	HIGH	MEDIUM	LOW

文档属性	内容
报告编号	BTS-SEC-2026-1017
报告版本 / 状态	1.0 / 初次审计最终报告；修复尚未复测
审计日期	2026-10-17（Australia/Sydney）
受审产品	BitTool Signer 1.0.0 (build 1)
出名人 / 报告署名	GPT-6 Astra（按委托方指定）

本报告采用企业安全审计的组织方式，由 AI 辅助代码审查和本地验证生成。署名不代表 OpenAI 或任何商业审计机构签发；未取得认证、保险、法律鉴证或第三方独立审计背书。

01 / DOCUMENT CONTROL

文档控制与阅读导航

项目	约定
委托范围	全仓第一方代码审查，重点为钱包密钥、JS 解析与签名、原生桥接和审核界面。
交付物	本 PDF；配套证据包包含 PoC、原始输出、构建与依赖结果、源文件哈希清单。
产品改动	本轮为审查与验证，未修复或修改产品源码。新增内容仅为审计证据、构建产物与报告。
状态含义	Confirmed/Open：已证实、尚未修复；Observation：设计或流程建议；Not verified：没有取得相应验证证据。
分发建议	限产品负责人、开发、安全与发布人员。对外分享前应保留范围和限制说明，避免截取为“审计通过”证书。

阅读顺序

主题	页码
管理层结论、范围、威胁模型与方法	3 - 6
发现清单与四项详细问题	7 - 13
安全控制、协议、依赖及设计观察	14 - 18
测试证据、修复路线与放行条件	19 - 21
文件覆盖、随包依赖与参考资料	22 - 25

审计状态与签核

初次审查已完成，所有发现保留为 Open。未收到修复提交或管理层风险接受意见；本报告不代替后续复测。文档完成由报告署名负责，产品放行仍须由产品与安全负责人决定。

报告署名：GPT-6 Astra
签发日期：2026-10-17
机构盖章 / 独立机构签名：不适用。

02 / EXECUTIVE SUMMARY

管理层摘要

结论：暂缓真实资金发布

签名算法与密钥保管有较完整防护，但“看见什么、授权什么”的核心体验存在资金金额误导。两项 High 应作为发布阻断项。

0	2	1	1
CRITICAL	HIGH	MEDIUM	LOW

本次确认 4 项产品问题：2 High、1 Medium、1 Low；未确认 Critical。未发现可证明的私钥外传、无需钱包密码签名或任意请求篡改后仍被授权的路径。这些结论仅适用于已审快照，不能解释为没有其他漏洞。

最重要的问题	钱包后果
BTC 非零 OP_RETURN 未纳入主摘要	1 BTC 输入可烧毁 0.99 BTC，首页仍显示“所有输出返回钱包”。签名能够成功。
EVM / Safe MultiSend 只显示内层金额	外层支付 100 ETH，主摘要仅为 0.001 ETH。EOA 交易与 Safe CALL 均已复现。
TRON 能量预算被标为总费用上限	可显示“0 TRX max”，但实际协议可能另外计收带宽和操作费用。
有效日语 / 韩语助记词被拒绝	NFKD 后超过 512 bytes 的合法 BIP39 备份无法在本 App 导入。

问题的共同根因

最重要的漏洞并非签错哈希，而是对已经正确解析的字节做了不完整的经济语义汇总。通用风险提示和深层明细不足以抵消主卡片对金额、找零或费用上限的错误表达。

已核验的基础能力

逐次钱包密码授权、双层认证加密、设备 Keychain 密钥、公开索引 HMAC、固定签名计划、秘密操作新建 JavaScriptCore 上下文、严格输入边界和出站响应重解码均有实际实现。生产依赖公告检查为零命中，干净重建与随包 JS 完全一致。

03 / SCOPE AND BASELINE

范围与版本身份

审计对象为提供的本地工作目录，项目和 package 版本均为 1.0.0，构建号为 1。Git HEAD 仍为 Initial Commit，大量 BitToolSigner 代码处于未跟踪状态；因此不能用该提交声称覆盖当前版本。

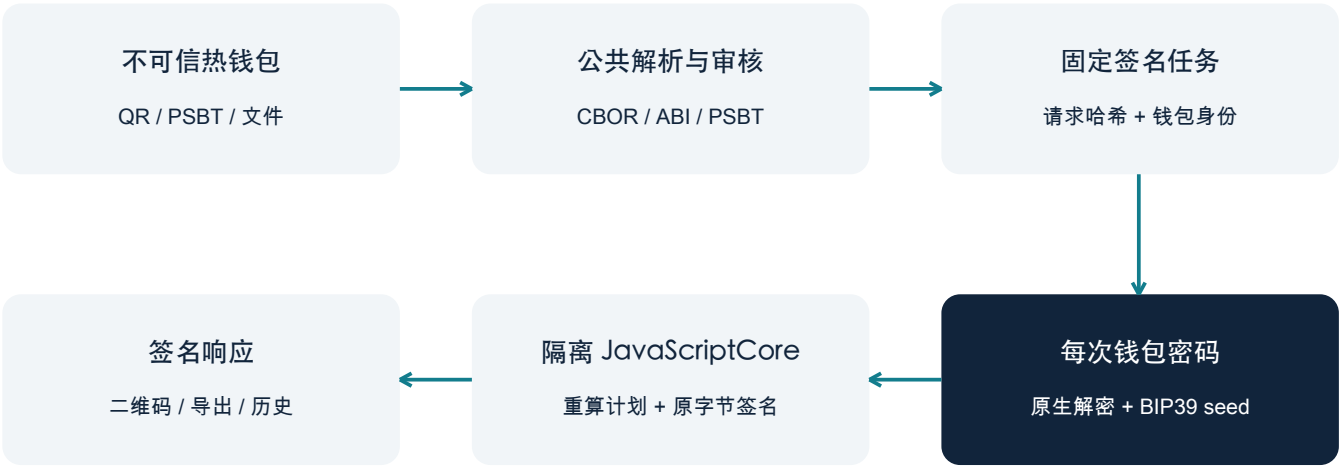
基准	内容
Git HEAD（仅环境记录）	95baad4e242fe79cd15734f3eb982e90eff698ac
JS bundle 大小	1,175,844 bytes
JS SHA-256	15edf52c5ba20ff9b422e08b8e7d822559c629cd943f888532928a36bb6df895
清单根 SHA-256	646fcc44d005ec3230137e57fc0a54cfeb2dd7e22603f0508b7acf8d8270e35b
哈希清单范围	829 个第一方源码、配置、资源、测试、工具和翻译文件；不包含 node_modules、构建目录和审计输出。

分区	代码文件 / 行数	审查方式
iOS 应用	48 Swift / 11,271 行	安全核心逐段审查；跨 UI 调用链复核
JavaScript 引擎及测试	27 JS/MJS / 6,260 行	15 个运行时模块 + build；测试与向量检查
原生 / UI 测试	26 Swift / 4,835 行	现有测试逻辑审阅；本轮运行范围另列
开发工具	10 文件 / 3,029 行	全部脚本静态阅读；未运行联网生成器
静态资源 / 依赖	词表、注册表、图标、锁文件	结构、哈希、用例、来源与实际打包贡献检查

行数为物理行，排除生成的 signer.js；不是有效代码行数、覆盖率或安全保证。829 个文件的哈希盘点不表示每个二进制资产都经过人工逐字节审计。第三方密码库内部未做独立完整数学证明。

04 / TRUST BOUNDARIES

架构与威胁模型



风险集中在“字节被正确签名，但主摘要未完整表达资金后果”的信任边界。

资产 / 攻击者能力	本次假设
核心资产	助记词、BIP39 passphrase、设备密钥、私钥；签名授权完整性；收款地址真实性；恢复可用性。
主要攻击者	控制热钱包、网页或请求文件，可发送任意结构的 QR/PSBT/签名请求及元数据；知道公开钱包地址。
用户行为	用户可被不准确摘要误导并输入自己的钱包密码。此类用户交互是离线签名器必须面对的威胁。
另行考虑	应用容器被篡改、备份卡片泄露、恶意或错误构建依赖、设备截图或录屏。
不作为已验证前提	本轮没有证明 iOS/JSC 漏洞、越狱后隔离能力、恶意发行签名、物理芯片攻击或任意原生代码执行。

离线运行减少网络攻击面，但不阻止恶意输入进入，也不保证已签授权安全。App 只提供签名，不广播交易；签名离开设备后，协调钱包或持有人可能使用它。

05 / METHODOLOGY

方法、证据与风险标准

工作流	实施内容
静态审查	按密钥生命周期、输入解析、显示语义、计划绑定、签名与输出追踪数据流；并行审查后交叉复核高风险项。
动态验证	运行现有 JS 测试；构造公开无资金 PoC；核对源码与随包 bundle；独立验签或 PSBT finalize。
原生验证	检查真实 Swift 函数的 BIP39 边界；编译 Release；执行 iOS 模拟器单元测试，环境失败单独记录。
供应链	查询 npm 官方审计接口；按 lockfile 全新安装且禁用脚本；在内存重建 JS；检查输出贡献与正式包内容。
标准参照	采用 OWASP MASVS 的存储、密码、授权、平台、代码与隐私分类作为检查视角；结合 BIP39、PSBT、EIP-712 及链官方语义。

严重度定义

等级	判定原则
Critical	已证明可普遍直接窃取密钥或造成大范围无授权资产损失。
High	在明确可行条件下可能造成重大、不可逆资金损失或关键授权误导；即使仍需用户操作也可成立。
Medium	有可复现的安全语义缺陷或额外成本风险，影响和利用范围较有限。
Low	兼容性、恢复可用性或较低影响缺陷，未证明资产被盗或既有钱包丢失。

本报告使用产品情境严重度与修复优先级，不伪造 CVE、官方 CVSS 分数或 MASVS 认证。证据分为：E1 实际可执行复现；E2 源码与官方规范支持；E3 尚未实测的观察或外部验收。

06 / FINDING REGISTER

发现登记表

编号 / 严重度	发现	证据 / 状态
BTS-01 High / P1	Bitcoin 非零 OP_RETURN 销毁金额被主摘要遗漏	源码与 bundle 签名及 finalize E1 / Open
BTS-02 High / P1	EVM / Safe MultiSend 外层原生币金额被内层汇总覆盖	QR → 固定计划 → 真实签名 E1 / Open
BTS-03 Medium / P2	TRON fee_limit 被当作总网络费用上限	生产 bundle 显示 + 协议核对 E1/E2 / Open
BTS-04 Low / P2	BIP39 字节上限拒绝有效长日语 / 韩语助记词	当前 Swift 函数 + 独立词表验证 E1 / Open

利用条件与影响边界

• BTS-01 / BTS-02 均需要攻击者提供恶意请求、用户审核并输入密码；没有证明密码绕过。真实金额仍在完整明细，缺陷在于主要摘要错误。

• BTS-02 已有 high 风险勾选；本报告没有将其写成风险确认绕过。Safe 路径还需满足真实 Safe 的 owner、threshold 和 nonce 条件。

• BTS-03 不修改收款人或交易字节，影响为错误费用预期。BTS-04 在钱包保存前失败，不会据此创建损坏钱包。

修复顺序

先修 BTS-01 和 BTS-02，并用资金流不变量防止同类错误；随后修费用模型和恢复输入边界。观察项应进入维护计划，但不与已确认资金漏洞混为一谈。

发布门槛

两项 High 在修复版本上仍可复现时，不应放行。必须对源码、重新生成的 JS 和实际 iOS 界面同时回归。

07 / HIGH - BITCOIN REVIEW

BTS-01 | 烧币被标为返还钱包

输入	不可花费输出	真实找零
1 BTC	0.99 BTC	0.00999 BTC

根据本次 PoC 输出绘制；不是 App 截图。所有金额均来自无资金测试向量。

主摘要错误地将包含非零 OP_RETURN 的交易描述为 Consolidate / All outputs return to your wallet。此输出在 Bitcoin 中不可花费；签名后广播可能永久销毁对应 BTC。

代码定位：engine/src/bitcoin.js:32-38、105-117；engine/src/resolver.js:141-150；BitToolSigner/Features/Sign/RequestReviewView.swift:279-304；Models/Models.swift:369。

根因与路径

bitcoinDisplay() 先排除所有 data 输出，再计算外付金额。如果剩余输出都被正确证明为本钱包找零，函数即返回“全部返回钱包”。这将“0 BTC 的数据输出”和“携带 BTC 的不可花费输出”视为同类。

```
const payments = outputs.filter(o => !o.data && !change.has(o.index));
// No remaining payments -> Consolidate
headline: "All outputs return to your wallet"
```

原生主卡片直接展示 display.action/headline。复现的 review 为 fullyDecoded + warning，既不触发 high 标记，也不要求风险勾选。用户仍须输入钱包密码。

已存在但不充分的提示

完整字段保留 Output 2: 0.99 BTC / OP_RETURN，警告也写明存在不可花费数据输出。因此不是金额在全界面消失；问题是最显著的结论与实际资金后果矛盾，且没有直接指出“将销毁 0.99 BTC”。

严重度理由

可以用看似内部归集的请求诱导不可逆资产销毁，金额可占输入的大部分。影响为资金完整性，定为 High；未主张攻击者可以绕过密码或直接获得这些 BTC。

07 / BITCOIN - REPRODUCTION

BTS-01 | 复现与修复要求

步骤	观察结果
1. 构造公开测试钱包和合成前序交易	输入 100,000,000 sat；固定已知测试助记词。
2. 设置两个输出	本钱包找零 999,000 sat；OP_RETURN 99,000,000 sat；手续费 1,000 sat。
3. resolveSigningPlan	status=ready；fullyDecoded；warning；主摘要称全部返回。
4. signPlanTask	没有提供 riskAcknowledged；成功得到签名。
5. 独立 PSBT finalize / extract	得到 203-byte 已签交易；烧币输出保持 99,000,000 sat。
6. 运行对照和生产 bundle	0-value OP_RETURN 对照正常；源模块与随包 signer.js 均复现问题。

PoC 不涉及用户钱包，不查询真实 UTXO，也未广播交易。合成前序交易用于证明应用的审核、授权和签名路径；可广播性的网络资金前提需在受控 regtest / testnet 另行验收。

建议修复

• 默认拒绝 amount > 0 的 OP_RETURN，除非产品明确支持销毁。保留支持时，单列销毁总额和净支出，并要求逐次高风险确认。

• “全部返回钱包”的必要条件应包含所有非手续费价值都可由本钱包花费，不能仅依据剩余 payments 为空。

• 建立不变量：输入 = 可花费外付 + 本钱包找零 + 销毁 + 手续费；每一项都必须在审核中可解释。

回归验收

覆盖零值 / 非零 OP_RETURN、一个或多个销毁输出、外付与找零混合、多签多个本地任务、PSBT v0/v2；验证 JSON 主摘要和 iOS 主卡都不得再显示错误全额返还。

证据：btc-op-return-poc.mjs；btc-op-return-poc-result.jsonl；btc-solana-findings.json。

08 / HIGH - EVM AND SAFE

BTS-02 | MultiSend 主金额低报

主摘要	签名的外层 value	两者相差
0.001 ETH	100 ETH	99.999 ETH

根据本次 PoC 输出绘制；不是 App 截图。所有金额均来自无资金测试向量。

EVM 批处理的主金额来自内层转账合计，外层实际支付的原生币 value 被漏掉。对 Safe MultiSendCallOnly 的直接调用，以及 SafeTx operation=CALL，都可能出现外层 100 ETH、主摘要仅 0.001 ETH 的结果。

代码定位：engine/src/evm.js:244-289，尤其 274、286；SafeTx 484-490；RequestReviewView.swift:279-304。

根因

decodeCall() 遍历内层调用并累加 moved，用它填充 display.amount。随后“附带原生币”提醒分支明确跳过 multiSend，因此不会像普通合约调用那样突出外层的 100 ETH。SafeTx 复用了同一个解码函数。

实际后果与验证边界

签名交易的 value 已验证为 100 ETH。官方 Safe v1.4.1 MultiSendCallOnly 为 public payable，按内层 value 执行 CALL，未验证外层与内层总额相等，也无剩余金额退款逻辑。[R4]

据官方源码推断，该示例的 99.999 ETH 余款会留在可公开调用的合约，并可被后续调用转出。本次没有执行本地 EVM 或链上广播，不能将这一后续领取描述为已实测；高风险结论本身已有真实签名支出 100 ETH 与主摘要不符的证据。

已有防护

完整字段仍包含 Native amount = 100 ETH；一般 high 风险勾选、钱包密码和 Safe 权限条件仍然存在。该问题是关键资金信息误导，不是签名算法故障或权限绕过。

08 / MULTISEND - REPRODUCTION

BTS-02 | 复现与修复要求

项目	结果
调用目标	Safe MultiSendCallOnly v1.4.1 0x9641d764fc13c8B624c04430C7356C1C7C8102e2
外层 / 内层	外层 100 ETH；内层 1 个 CALL 仅转出 0.001 ETH。
审核显示	Batch Transaction；1 call: Send (0.001 ETH)；主金额 0.001 ETH。
签名验证	公开 eth-sign-request QR → 固定计划 → signPlanTask；EIP-1559 交易实际 value=100 ETH。
Safe 变体	SafeTx operation=0 / CALL 同样显示 0.001 ETH，签名内容中的 Safe value=100 ETH。
对照	同样附带 100 ETH 的普通非 MultiSend 调用，会显示 100 ETH 并提示附带金额。
生产包	随附 signer.js 的 review 与签名同样复现，非仅开发模块行为。

建议修复

• 主卡单独展示“从钱包支付到调用目标的原生币”和“批处理内部转账合计”，不得用一个数字替代两个不同语义的数值。

• 直接交易 / Safe CALL 的外层 value 非零时始终突出；高亮与内层合计的差额。合计不相等不是所有批处理都应拒绝，但必须说明差额和无法确认的余额去向。

• 对 Safe DELEGATECALL 单独建模：内层 value 可以从 Safe 自身余额支付，不能简单把外层 value 当内层支出上限。

回归验收

测试外层大于、等于、小于内层合计，零外层但内层非零，嵌套批处理，EOA CALL / Safe CALL / DELEGATECALL，以及混合 ERC20/NFT/原生币。断言主卡不会少报任何已知原生币支出。

证据：evm-multisend-value-poc.mjs；evm-multisend-value-evidence.json；evm-independent-run.log。

09 / MEDIUM - FEE SEMANTICS

BTS-03 | TRON 费用上限错误

已确认：能量预算不等于总费用上限

TRX 转账和权限更新请求可以显示“Network fee up to 0 TRX max”。显示来自缺失 fee_limit 时的默认 0，而非已证明交易总费用为零。

代码定位：engine/src/tron.js:49、83-90；BitToolSigner/Features/Sign/RequestReviewView.swift:331-334。

TRON 的 fee_limit 限制调用者侧能量预算；普通交易的带宽费用以及权限更新等额外操作费用不由该字段统一封顶。官方文档区分了这些收费路径。[R5][R6]

复现请求	观察
普通 TRX 转账	display.fee = 0 TRX max；可成功产生 65-byte 签名。
AccountPermissionUpdate	同样显示 0 TRX max；权限修改已有 high 风险提示，但没有说明总费用上限未知。
生产 bundle	两种请求在随 App signer.js 中均复现。

影响和前置条件

用户可能在错误的费用承诺下授权额外 TRX 支出。实际收费取决于账户资源、交易类型和治理参数；没有进行实时链参数查询或链上执行。本项不证明资金被转到攻击者地址，也不主张某一固定费用永远有效。

建议修复与回归

• 将字段命名为“能量预算上限”，并将“总手续费：离线无法确定”独立展示；不适用的交易不要显示能量 0 等同总费 0。

• 对于带宽、账户创建、权限变更和多签等额外费用给出分类提示，避免硬编码会随治理变化的总费用承诺。

• 覆盖无 fee_limit 的转账和权限更新、带 fee_limit 的合约调用、已有多签签名、资源不足情境；核对引擎与原生标签一致。

证据：tron-fee-ceiling-poc.mjs；tron-fee-ceiling-evidence.json；tron-independent-run.log。

10 / LOW - BIP39 COMPATIBILITY

BTS-04 | 合法备份恢复被拒绝

原生 seed 派生对 NFKD 后助记词设置 512 UTF-8 bytes 上限，低于部分有效官方日语 / 韩语 BIP39 短语的长度。界面校验 checksum 成功后，在创建钱包的 seed 派生阶段失败。

代码定位：BitToolSigner/Core/BIP39Seed.swift:12-19；Models/AppStore.swift:184-185；Features/Setup/WalletSetupModel.swift:65-96。

语言 / 词数	NFKD bytes	当前原生结果
日语 12 / 15 / 18	323 / 404 / 488	成功（对照）
日语 21 / 24	575 / 653	invalidSecret
韩语 12 / 15	389 / 494	成功（对照）
韩语 18 / 21 / 24	596 / 695 / 800	invalidSecret

10 个构造向量全部通过独立 @scure/bip39 校验；复制当前未改动的 BIP39Seed 函数，在 macOS Swift harness 实际执行，5 个有效长向量被拒绝。结果证明函数边界问题，但不替代完整 iOS 导入 UI 测试。

影响边界

受影响用户无法在本 App 恢复这些合法钱包。失败发生在保存前，不会由此创建不能再解锁的坏 vault；已有链上资金仍可在符合 BIP39 的其他实现中恢复。英语新建钱包不受此具体问题影响。

建议修复

以官方词表、支持词数和 checksum 为主要验证，采用经词表最大长度验证的 UTF-8 上限。保留防超长输入边界，但应允许所有合法语言向量。增加十种语言 × 五种词数的长短边界和独立 seed 一致性测试。

证据：native-bip39-limit-vectors.json；native-bip39-reference-results.json；native-bip39-length.swift；native-bip39-length-output.txt。[R2]

11 / CONTROL ASSESSMENT

密钥与原生安全控制

控制面	已核实实现	保留边界
随机数 / KDF	SecRandomCopyBytes；PBKDF2-HMAC-SHA256 600,000 次；32-byte 随机 salt；参数有界。	没有将密码组成规则等同高熵；不声称 Argon2 级抗并行能力。
Vault 加密	密码 AES-256-GCM + 独立设备密钥 AES-GCM；两层认证精确 header 字节和域标签。	密码、设备密钥、可恢复备份仍是独立安全要素。
设备密钥	WhenPasscodeSetThisDeviceOnly；禁止同步；无生产弱保护 fallback。	不是 Secure Enclave 内的链上签名；真实设备失密行为未实测。
文件存储	Complete protection、备份排除、0600/0700、预设置属性后原子替换。	真机断电 / 备份恢复 / 重装场景仍需验证。
公开索引	HMAC 绑定 wallet UUID 和原始 body；篡改后要求单钱包修复。	本地任意原生代码执行不在其防护保证内。
签名授权	每个任务独立密码；request/plan/task/wallet identity 绑定；解密后重算目标。	未发现无密码签名路径；不能修正错误的经济摘要。
生命周期	后台 security epoch、取消旧异步结果、隐私遮盖；App Lock 与签名授权分离。	屏幕截图通知发生在截图之后，不能追回已泄露影像。
JS 桥接	仅本地 bundle；参数传值不拼接脚本；秘密/外部输入新 VM；原生熵桥闭包封装。	GC / Swift String 不保证所有秘密副本可靠清零。

评级为“已见实现和相应证据”，不代表对所有设备、所有 OS 情况完成认证。最终 Release 包还检查了 DEBUG Simulator fixture 的排除。

12 / CHAIN AND AUTHORIZATION COVERAGE

多链与授权语义覆盖

范围	已审查的防护 / 边界	结论
Bitcoin	前序交易 txid/脚本验证；legacy/SegWit v0 完整 prevtx；Taproot commitment；ALL/DEFAULT；已有签名验签；找零公钥重推导。	BTS-01；未确认额外签名绕过。
EVM / EIP-712	交易网络/类型；精确 ABI 重编码；整数与 bool 强类型；domain 字段和顺序；Permit / Permit2 / Safe refund；请求重绑定。	BTS-02；typed data 本身仍需依赖实际合约语义。
NFT / 授权	ERC721/1155、Seaport/LooksRare/Blur 等；完整 token ID、maker/offer/consideration、部分解析和高风险提示。	没有将 registry 命中等同安全；未知或根承诺仍有限制。
TRON	严格 protobuf；raw_data JSON 与签名字节一致；权限 ID 与已存签名；Stake 2.0；TIP191 字节与长度前缀。	BTS-03；离线无法验证当前 owner/权重/网络。
Solana	固定 signer slot；原字节签名；既有签名校验；静态 keys；ALT 拒绝；未知程序 / 扩展 risk gating。	未确认新增 High/Critical；未模拟任意链上程序。
Resolver / public-index	公钥、地址、路径、脚本与身份一致性；歧义拒绝；固定任务；解锁后重算。	未确认替换钱包或请求后沿用授权。

防误报复核

没有把支持 PSBT 容器等同支持所有 spend；没有把 EIP-712 签名等同已验证合约安全；没有把 Solana 部分指令解析等同完整模拟。Taproot 元数据承诺、Metaplex 的 owner/edition 检查以及原生风险 gate 均做了调用链复核，未把未证实猜测升级为漏洞。

相关分支额外运行 92 项既有测试全部通过；这些测试属于 179 项总套件的子集，不重复累加统计。

13 / TRANSPORT SECURITY

二维码、输入与输出边界

边界	核实结果
输入大小	dispatch 1 MiB；QR payload 128 KiB；每帧 4,300 chars；2,048 帧；累计约 1 MiB。
CBOR / JSON	确定长度 CBOR、深度/复杂度上限、重复键拒绝；CBOR 精确整数范围与 UTF-8 校验；JSON 归一化后的安全整数检查；尾随数据拒绝。
UR fountain	序号/分片数/长度/checksum 一致性；混合 session 拒绝；独立 scan VM。
BBQR	编码、索引、重复冲突与块大小验证；分段 DEFLATE 解压并限制输出。
原始载荷绑定	从保存的 QR CBOR 重建 request 并比较 requestHash；PSBT 原始 payload 比较。
输出	协议回传保留 opaque ID；生成 QR 后重新解码，验证类型与实际载荷。

补充变异验证

除现有协议用例外，本次增加了固定随机种子的有限变异测试，先修改 CBOR 再生成有效 checksum 的 UR，覆盖更深解析路径；同时包含 JSON / BBQR 边界。详细计数与运行时保存在 protocol-mutation-results.json。

样本 / 结果	实测统计
样本	1,509 例；seed=0x20261017
结果	292 接受；1,167 拒绝；50 未完成
异常检查	未捕获异常、源码/bundle 差异、绑定失败、边界预期失败均为 0
资源边界	2.596 秒；Node old-space 256 MiB；结束 RSS 139 MiB（非峰值）

部分变异仍是有效请求，接受本身不是漏洞；已接受载荷另作 transport 重建绑定检查。JSON 接受 NBSP，且某些小数/指数先由 Number 舍入；尚未证明审核与签名不一致，作为加固建议。该变异实验不执行签名。

残余工作

建议在 CI 中加入持续 coverage-guided fuzzing、每操作执行时间和峰值内存预算，并在较慢真实设备上压力验证。现有上限有助于限制输入，但不能据此推导所有路径都有确定的时间上界。

本次没有确认 QR 到原生代码执行、外部脚本插入或密钥从输出协议泄露的可复现路径。

14 / SUPPLY CHAIN

供应链与可复现构建

检查	实际结果
生产公告查询	npm audit --omit=dev：0 命中。仅表示当前数据库没有返回公告，不证明依赖无未知漏洞。
全部依赖查询	6 个受影响包节点：3 moderate、3 low；对应 uuid 与 elliptic 两组根公告。均位于开发测试依赖链。
生产可达性	esbuild 输出贡献中无 uuid、elliptic、hdkey、secp256k1 或 Keystone 测试 registries；未据此报告生产私钥漏洞。
干净安装	独立临时目录 npm ci --ignore-scripts；未修改产品 node_modules。官方包按锁文件校验后安装。
重建一致性	本地现有依赖及干净安装两次内存重建均与随包 signer.js 逐字节一致。
正式包	Release iPhoneOS 构建成功；App 内 signer.js 哈希一致；抽查 fixture 字符串和测试资源未检出。
离线边界	输出贡献未见 ethers fetch/provider/websocket/http 模块。开发脚本联网与 App 运行时网络路径分别评估。

开发依赖公告

uuid：GHSA-w5hq-g745-h8pq，受影响 API 为外部 buffer 参数下的 v3/v5/v6 边界检查。[R7] elliptic：GHSA-848j-6mx2-7j84，涉及 ECDSA 实现风险。[R8] 当前生产签名使用 noble/scure/ethers 实际随包路径；不要将测试依赖公告直接等同 App 正在泄露私钥。

建议更新或隔离开发测试依赖，对每条公告记录可达性与风险接受期限。不要盲目使用 npm audit fix --force，因为工具给出的自动版本调整可能破坏协议 fixture。

JS SHA-256：15edf52c5ba20ff9b422e08b8e7d822559c629cd943f888532928a36bb6df895

15 / OBSERVATIONS - NOT CONFIRMED EXPLOITS

设计观察与维护事项

编号	观察与建议
O-01 备份卡	当前三张卡各披露 2/3 助记词，不是密码学门限共享。单卡剩余搜索空间约为 40/50/60/70/80 bits（12/15/18/21/24 词，计 checksum 约束）。12/15 已警告；建议所有长度说明降强度，并避免绝对安全措辞。未进行暴力破解实验。
O-02 本地限速	attempts 计数文件缺失会重置，墙钟参与延迟。需容器写入或时间控制等本地条件，不绕过 PBKDF2、设备密钥或密码。不要描述为远程绕锁。
O-03 内存与签名留存	Swift/JS 秘密副本难以保证清零；已签授权也可能在使用前仍有效。保护最近 25 条响应记录、导出文件和设备访问，区分撤销 UI 状态与撤销已产生签名。
O-04 数据与构建	增量 token 数据刷新可能沿用旧测量但统一更新 checkedAt。建议区分 lastFetched 与 lastVerified，记录每条数据及来源；离线 registry 不验证当前合约行为。
O-05 工具维护	fetch-wallet-logo.py 输出目录名与实际 BitToolSigner 不一致；翻译参数检查排序后可能放过非 positional 重排。当前翻译未发现受影响项，未列入钱包资金漏洞。
O-06 开发依赖	两组根安全公告均未贡献到当前生产 JS，作为开发供应链整改跟踪。

以上观察不计入 4 项产品发现总数，也不表示已证明可利用的远程攻击。优先级应结合真实设备威胁模型和发布流程确定。

16 / VALIDATION RESULTS

本次执行与验证记录

验证	本次结果 / 边界
完整 JS suite	179 / 179 通过；无 skip、fail 或 cancel。现有套件未覆盖此次四项问题的完整边界。
BTC PoC	源码 + 随包 bundle；0-value 对照与非零烧币请求；签名并 finalize 成功。
EVM / Safe PoC	源码 + bundle；EOA 和 Safe CALL；真实签名值核对；普通调用金额对照。
TRON PoC	转账 / 权限更新显示 0 TRX max；源码与 bundle 相同；未广播。
BIP39 边界	10 / 10 独立合法性验证；当前 Swift 派生 5 成功、5 因上限拒绝。
原生 unit tests	Swift Testing 152 项通过；XCTest 3 项通过。
iOS Release	Xcode 26.4 / iPhoneOS；CODE_SIGNING_ALLOWED=NO；BUILD SUCCEEDED。
可复现 JS	干净安装后 1,175,844 bytes 与生产 bundle SHA-256 完全一致。
依赖扫描	生产 0；全依赖 6 包节点 / 2 组根公告；已检查生产可达性。

环境和异常处理

Node.js 20.20.2，npm 10.8.2，Xcode 26.4 (17E192)。iOS 26.4 模拟器最初两次因克隆 / 启动失败，未执行测试；后切换已就绪设备执行。环境错误不计作产品测试失败，也不隐藏在总体结果之外。

真实 iPhone、相机扫码、完整 XCUITest UI 套件、签名 App Store archive、设备失密与链上互操作未在本次完成。

17 / REMEDIATION PLAN

修复路线与验收标准

优先级 / 责任建议	工作项	关闭标准
P1 / JS + iOS 审核	BTS-01：数据输出金额归入资金流；默认拒绝非零 OP_RETURN 或显式销毁确认。	全部已知价值守恒；源码、bundle 和 iOS 主卡都不再称错误全额返还。
P1 / JS EVM + Safe	BTS-02：独立表示外层支出、内层支出和差额；分别建模 CALL / DELEGATECALL。	100 ETH / 0.001 ETH PoC 不再低报主支出；嵌套和混合资产回归通过。
P2 / TRON + UI	BTS-03：费用类型化；能量预算和未知总费用分开。	无 fee_limit 请求不再宣称总费最多 0；额外费清晰披露。
P2 / 原生恢复	BTS-04：允许全部合法语言和词数的派生长度。	全部边界向量 native/reference seed 一致；失败在安全边界内可解释。
P2 / 构建与测试	加入安全负向用例、可复现 JS 检查、开发公告可达性记录。	锁定修复提交与 bundle 哈希；CI 可复现所有已关闭项。
发行前 / QA + 安全	真机、钱包互操作、生命周期与签名归档检查。	形成设备 / OS / 钱包版本 / 请求类型 / 预期结果矩阵与证据。

复测纪律

每项修复应提供 commit、变更说明、对应回归用例、生成的 signer.js 和新 manifest。复测从原始 PoC 开始，再覆盖同类边界；不得仅靠修改文字或提高通用风险等级关闭金额缺陷。

本报告没有给出修复工期承诺。风险关闭状态只有在新版本上取得证据后才可更新为 Fixed / Retested。

18 / RELEASE DECISION AND LIMITS

放行条件与审计限制

当前意见：不予安全放行

该结论基于两项已证实、可能造成大额不可逆资金后果的审核缺陷。不是对所有代码质量的否定，也不是对任一未来修复版本的预判。

建议的放行条件

- BTS-01 / BTS-02 修复并交叉复测；BTS-03 / BTS-04 完成修复或有具体、有期限的产品风险决策。
- 受审代码进入可标识的提交或签名 tag；生成并保留源清单、依赖锁文件、JS 和最终归档哈希。
- 用实际设备验证 Keychain、密码移除、备份排除、文件保护、后台/录屏/截图行为和密码更新中断。
- 对每个宣称支持的钱包版本与协议做无资金或受控测试网端到端签名互通；安全复测使用一次性钱包。

本报告没有验证的内容

没有私钥侧信道或密码库数学证明；没有长期覆盖引导 fuzzing；没有 iOS / JavaScriptCore 0-day 研究；没有真实网络合约模拟或生产资金试验；没有供应链运营组织控制、应用商店签名与发布权限审计。

动态网络状态、token 元数据、Safe/TRON 当前成员、Solana 程序与权限以及用户设备可信性，均不能单靠此离线源代码报告证明。干净 npm 重建证明本次来源与输出一致，不保证未来依赖或开发机未被入侵。

最终审计意见

基础密钥保护和请求绑定设计值得保留。首要修复目标是让主审核界面忠实表达所有可确定的资产支出、销毁和费用边界。在这些问题关闭前，不建议将 1.0.0 当前快照用于真实资金保管或对外宣传为“已安全审计通过”。

报告署名：GPT-6 Astra（委托方指定）
状态：初次审计结束，整改与复测待完成。

APPENDIX A / COVERAGE INVENTORY

附录 A | 第一方代码覆盖索引

模块	范围与深度
JS 运行时	完整审查：bitcoin、bitcoin-policy、evm、nft-orders、tron、solana、resolver、public-index、keys、util、index、polyfills、known-contracts、token-registry、protocols。
原生 Core / Models	VaultCrypto、WalletVault、SigningEngine、BIP39Seed、PasswordPolicy；AppStore、Models、BIP39Wordlist、RecoveryCards、BackupVerification、AppLanguage、CompatibleWallets。
Services / app	AppAccessController、PrivacyShield、PublicWalletRepository、RecoveryPrivacySession、RecoveryScreenshotSession、SimulatorUITestContext、TokenIconStore、BitToolSignerApp。
Features	Sign 全流程；Setup、Backup、Lock；Wallets 详情、SecuritySheets、Addresses、Connect；Main root/router/tabs；Activity；Settings；Onboarding。
Design	AddressText、QRCodeView、PasswordViews、PayloadDisclosure、DesignSystem、Logos，结合敏感内容和审核调用点审查。
开发工具	prepare-icon.swift；build-third-party-licenses.mjs；8 个 Python 脚本，含 token/contract/icon/translation 数据生成。
配置 / 资源	pbxproj、PrivacyInfo、bundle/lock manifest、词表向量、资源哈希、注册表、翻译参数。
测试	engine/test；BitToolSignerTests；BitToolSignerUITests。UI 全套本轮未执行；运行记录以第 19 页为准。

全路径、字节长度和 SHA-256 在 source-manifest.json 中。源码盘点按第一方目录固定，第三方目录用锁文件和实际 bundle 贡献清单单独记录。资产、历史文档和设计图不作为“已执行测试”的证据。

APPENDIX B / BUNDLED COMPONENTS

附录 B | 实际随包依赖 1/2

按 esbuild bytesInOutput > 0 汇总，共 66 个安装路径、64 个独立 name@version；相同版本重复路径在此合并。字节为贡献估算，不含所有包装及注释。

组件	版本	贡献 bytes
@keystonehq/alias-sampling	0.1.2	1,197
@ngraveio/bc-ur	1.1.13	18,660
@noble/curves	1.2.0	22,644
@noble/curves	2.4.0	44,240
@noble/hashes	1.3.2	15,084
@noble/hashes	2.4.0	20,860
@scure/base	2.0.0	5,600
@scure/base	2.4.0	16,980
@scure/bip32	2.4.0	5,765
@scure/bip39	2.4.0	15,108
@scure/btc-signer	2.4.1	65,542
assert	2.1.0	30,569
available-typed-arrays	1.0.7	204
base64-js	1.5.1	1,469
bignumber.js	9.3.1	19,197
buffer	5.7.1	21,351
buffer	6.0.3	25,425
call-bind	1.0.9	423
call-bind-apply-helpers	1.0.2	630
call-bound	1.0.4	200
cbor-sync	1.0.4	10,384
crc	3.8.0	21,413
define-data-property	1.1.4	1,324
define-properties	1.2.1	590
dunder-proto	1.0.1	382
es-define-property	1.0.1	124
es-errors	1.3.0	388
es-object-atoms	1.1.2	52
ethers	6.17.0	86,269
fflate	0.8.3	4,505
for-each	0.3.5	639
function-bind	1.1.2	1,048

APPENDIX B / BUNDLED COMPONENTS

附录 B | 实际随包依赖 2/2

按 esbuild bytesInOutput > 0 汇总，共 66 个安装路径、64 个独立 name@version；相同版本重复路径在此合并。字节为贡献估算，不含所有包装及注释。

组件	版本	贡献 bytes
generator-function	2.0.1	85
get-intrinsic	1.3.0	8,294
get-proto	1.0.1	435
gopd	1.2.0	177
has-property-descriptors	1.0.2	208
has-symbols	1.1.0	1,062
has-tostringtag	1.0.2	103
hasown	2.0.4	134
ieee754	1.2.1	893
inherits	2.0.4	332
is-arguments	1.2.0	472
is-callable	1.2.7	1,414
is-generator-function	1.1.2	377
is-nan	1.3.2	538
is-regex	1.2.1	555
is-typed-array	1.1.15	84
isarray	2.0.5	115
jsbi	3.2.5	26,718
math-intrinsics	1.1.0	514
micro-packed	0.11.1	25,406
object-is	1.1.6	579
object-keys	1.1.1	2,345
object.assign	4.1.7	1,042
possible-typed-array-names	1.1.0	224
safe-buffer	5.2.1	804
safe-regex-test	1.1.0	210
set-function-length	1.2.2	510
sha.js	2.4.12	11,599
to-buffer	1.2.2	1,159
typed-array-buffer	1.0.3	190
util	0.12.5	12,045
which-typed-array	1.1.24	1,010

APPENDIX C / REFERENCES AND EVIDENCE

附录 C | 资料与复现导航

R1 · OWASP MASVS
https://mas.owasp.org/MASVS/

R2 · BIP39 官方规范
https://github.com/bitcoin/bips/blob/master/bip-0039.mediawiki

R3 · PSBT BIP174 / EIP-712
https://github.com/bitcoin/bips/blob/master/bip-0174.mediawiki

R3b · EIP-712
https://eips.ethereum.org/EIPS/eip-712

R4 · Safe MultiSendCallOnly v1.4.1 官方源码
https://raw.githubusercontent.com/safe-global/safe-smart-account/v1.4.1/contracts/libraries/MultiSendCallOnly.sol

R5 · TRON Resource Model
https://developers.tron.network/docs/resource-model

R6 · TRON Account Permission Management
https://developers.tron.network/docs/multi-signature

R7 · uuid 官方安全公告
https://github.com/uuidjs/uuid/security/advisories/GHSA-w5hq-g745-h8pq

R8 · elliptic 安全公告
https://github.com/advisories/GHSA-848j-6mx2-7j84

配套证据包

所有 PoC 仅使用公开、无资金测试向量。解压证据包到同一仓库根目录，保留 tmp/audit-2026-10-17 相对结构；安装锁定依赖后执行指定脚本。不要为这些公开助记词转入资金。

```
node tmp/audit-2026-10-17/btc-op-return-poc.mjs
node tmp/audit-2026-10-17/evm-multisend-value-poc.mjs
node tmp/audit-2026-10-17/tron-fee-ceiling-poc.mjs
node tmp/audit-2026-10-17/verify-build.mjs
```

主要取证文件：source-manifest.json、build-verification.json、release-inspection.json、npm-audit-production.json、npm-audit-all.json、原生测试日志、各问题 PoC 与 JSON 输出。参考资料检索日期为 2026-10-17；协议费率或主分支资料可能随时间变化。